



Wrocław
University
of Science
and Technology



Certificate Services

IT Infrastructure Management (W04IST-SI0826G)

Wojciech Thomas, PhD

Department of Applied Informatics
Faculty of Information and Communication Technology

Spring 2026



This week

After this lecture, you should be able to:

- Explain what PKI is and how certificates establish a chain of trust
- Compare Stand-alone and Enterprise CA types and choose the appropriate one
- Describe the certificate lifecycle: enrolment, distribution, use, revocation
- Configure an Enterprise CA integrated with Active Directory
- Explain how CDP and AIA locations affect certificate validation

2



Why this matters

- A company deploys an internal web application on HTTPS
- Browsers show a red "Not Secure" warning — users learn to click through and ignore it
- An attacker presents a self-signed certificate and intercepts the traffic
- **Today you will learn how to deploy a trusted internal CA so that never happens**

3



Agenda

- 1 PKI Fundamentals
- 2 AD Certificate Services
- 3 Managing certificates

5

What is PKI?

Public Key Infrastructure (PKI)

A system of policies, procedures, and technology for issuing, managing, and revoking **digital certificates** that bind public keys to identities.

PKI provides four security properties:

- **Confidentiality** — only the intended recipient can decrypt the data
- **Integrity** — data has not been altered in transit
- **Authenticity** — the server or user is who they claim to be
- **Non-repudiation** — the sender cannot deny having sent the message

How digital certificates work

- A **certificate** binds a **public key** to an identity — user, computer, or service
- The certificate is signed by a **Certification Authority (CA)** — a trusted third party
- Anyone who trusts the CA can verify the signature and trust the certificate
- Key certificate fields:
 - **Subject** — who the certificate belongs to
 - **Issuer** — who signed it (the CA)
 - **Validity period**
 - **Subject Alternative Names (SANs)** — additional names (eg. `www.dns.pl` and `dns.pl`)
 - **Key Usage / Extended Key Usage** — what operations are allowed with the certificate

Before we continue — predict

- You open a browser and navigate to an internal HTTPS site
- The site's certificate was issued by internal CA
- Your laptop has never connected to this CA before
- **What will the browser show, and why?**
- The browser shows a certificate warning — it cannot verify the chain of trust
- The Root CA certificate is not in the browser's trusted root store
- **Fix:** distribute the Root CA certificate via GPO
 - *Computer Configuration > Windows Settings > Security Settings > Public Key Policies*

Certificate trust chain

- Certificates form a **chain of trust** from a trusted root to the end-entity certificate:
 - **Root CA** — self-signed
 - **Subordinate (Issuing) CA** — signed by the root; issues certificates
 - **End-entity certificate** — the certificate used by subject

Why use a hierarchy?

- Root CA can be kept **offline** — reduces the risk of compromise
- A subordinate CA can be replaced without touching the root

PKI infrastructure elements

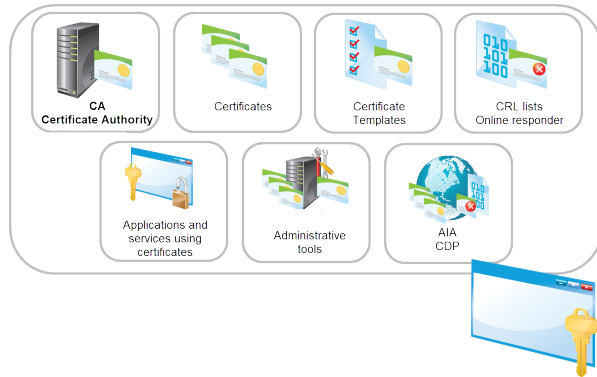


Figure 1: PKI infrastructure components

Certificate use cases

- **TLS/HTTPS** – server authentication and encrypted channel for web traffic
- **EFS (Encrypting File System)** – file is encrypted with a symmetric key, then the key is encrypted with the user's certificate public key
- **Document signing** – document is signed with a private key; anyone can verify with the public key
- **Smart cards** – user authenticates to AD with a certificate instead of a password
- **Network protocols** – IPsec machine authentication, 802.1X/EAP-TLS for Wi-Fi and wired LAN

Agenda

- 1 PKI Fundamentals
- 2 AD Certificate Services
- 3 Managing certificates

What is AD Certificate Services?

Active Directory Certificate Services (AD CS)

The Windows Server role that implements PKI – it issues, manages, and revokes certificates within a Windows domain environment.

Core AD CS role services:

- **Certification Authority** – the core service; manages certificates
- **CA Web Enrollment** – browser-based interface for manual certificate requests
- **Online Responder (OCSP)** – real-time revocation checking; faster than downloading a full CRL
- **Network Device Enrollment Service (NDES)** – issues certificates to routers and switches (SCEP)

Stand-alone vs Enterprise CA

	Stand-alone CA	Enterprise CA
Domain required	No	Yes
Certificate templates	No	Yes
GPO autoenrollment	No	Yes
Publishes CRL/AIA in AD	No	Yes
Issuance	Manual approval by default	Automatic (when template allows)
Best used as	Offline root CA	Issuing CA for domain members

CA deployment hierarchies

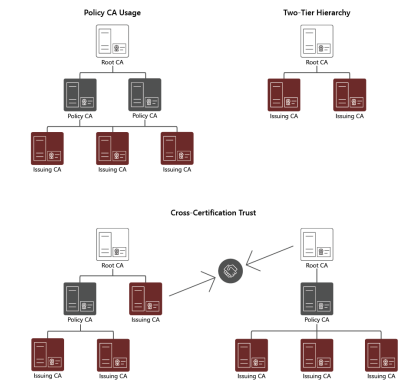


Figure 2: CA hierarchy deployment options

Admin challenge

Admin challenge

Your company has 50 IIS web servers in a Windows Server 2025 domain. You want every server to have a valid internal TLS certificate – renewed automatically, with no manual steps per server.

Design the CA type, hierarchy, and GPO configuration.

- **Enterprise CA** – supports GPO autoenrollment (Stand-alone cannot)
- Two-tier hierarchy: offline Root CA + online Enterprise Issuing CA
- Create a **Web Server** certificate template; enable autoenrollment on it
- Grant **Enroll** + **Autoenroll** to the domain computers security group
- Push autoenrollment via GPO:
 - Computer Configuration > Windows Settings > Security Settings > Public Key Policies > Certificate Services Client – Auto-Enrollment

Installing a Root CA

Key decisions **before** installation – **these cannot be changed later:**

- **Computer name and domain** – becomes part of every certificate the CA issues
- **CA type** – Stand-alone (offline root) or Enterprise (issuing CA)
- **Key length** – 4096-bit RSA recommended for root CAs
- **Hash algorithm** – SHA-256 minimum; SHA-1 is deprecated
- **Validity period** – root CA: 10–20 years; issuing CA: 5 years

Installation with PowerShell:

```
1 PS> Install-WindowsFeature -Name ADCS-Cert-Authority -IncludeManagementTools
2 PS> Install-AdcsCertificationAuthority -CAType EnterpriseRootCA
```

Subordinate Certification Authorities architecture

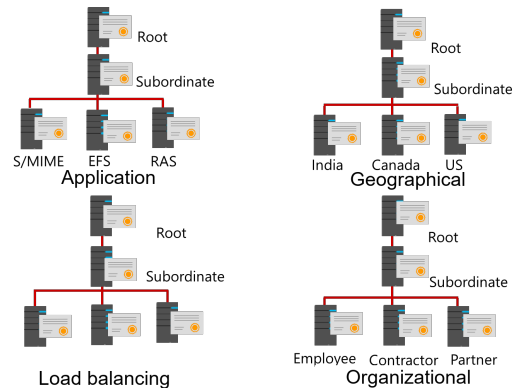


Figure 3: Subordinate CA organization options

Agenda

- 1 PKI Fundamentals
- 2 AD Certificate Services
- 3 Managing certificates

Certificates and templates

- A **certificate template** defines a blueprint for certificates
- Templates are stored in Active Directory; all Enterprise CAs in the domain share them
- A template specifies:
 - **Key usage and extended key usage** – purpose
 - **Validity and renewal period**
 - **Subject name format** – built from AD attributes or supplied by the requester
 - **Cryptographic settings** – key algorithm and minimum key size
 - **Issuance requirements** – CA approval, RA signature, etc.

Certificate template permissions

Access to a template is governed by AD permissions on the template object:

Permission	What it allows
Read	See the template in AD; required for all others
Write	Modify template settings
Enroll	Request a certificate based on this template
Autoenroll	Receive the certificate automatically via GPO
Full Control	All permissions including delegation

- Grant **Enroll** to users or computers that should be able to request the certificate
- Grant **Autoenroll** for zero-touch deployment via Group Policy

Certificate issuance methods

- 1 **Autoenrollment** — GPO triggers automatic request and installation; no user action needed
- 2 **Manual request** — user or admin uses `certmgr.msc` or `certlm.msc` MMC snap-ins
- 3 **Web enrollment** — browser-based request via the CA Web Enrollment role service
- 4 **Enrollment Agent** — a designated user requests certificates on behalf of others (e.g. for smart cards)

Configuring CDP and AIA

- **CDP** — Certificate Revocation List Distribution Point: where clients download the CRL to check if a certificate has been revoked
- **AIA** — Authority Information Access: where clients download the issuing CA certificate to build the chain of trust

Publishing locations configured on the CA:

- **AD DS (LDAP)** — accessible to domain members automatically
- **Web server (HTTP)** — accessible to all clients, including non-domain machines

Find the configured locations with PowerShell:

```
1 Get-CAcrlDistributionPoint
2 Get-CAAuthorityInformationAccess
```

Certificate revocation

Certificate revocation

A certificate is invalidated **before** its validity period ends
Do not mix it up with **expiry**

When to revoke:

- Private key is compromised
- Employee leaves the organization
- Certificate was issued in error

Certificate revocation 2

Revocation procedure:

- 1 Admin revokes the certificate in the CA console or with PowerShell
- 2 CA publishes an updated **CRL (Certificate Revocation List)**
- 3 Clients download the CRL from the CDP and check it before accepting any certificate

Revoke a certificate with PowerShell:

```
1 PS> Revoke-CACertificate -SerialNumber "1f2a..." -Reason "KeyCompromise"
```

Discuss with your neighbour (2 min)

- Your Root CA has been taken **offline** for security hardening
- Three months later, users report that internal HTTPS sites show certificate errors
- **Why is this happening? What should have been done before taking the CA offline?**
- The Root CA's CRL has expired – clients cannot verify revocation status and reject certificates
- Before going offline the CRL must be **published with a long validity period** (e.g. 6 months or more)
- The CRL must also be available at an **HTTP endpoint**, not just LDAP, for non-domain clients
- **Key lesson**: an offline Root CA must have its CRL pre-published and reachable – or it breaks every certificate it signed

Key archival

- **Key archival** – the CA stores an encrypted copy of the private key alongside the certificate
 - Only for **encryption** certificates (e.g. EFS keys)
 - Never for signing or authentication keys
- Configured per template and on the CA
 - requires a **Key Recovery Agent (KRA)** certificate

When are encryption keys lost?

- user profile deleted
- OS reinstalled
- disk failure
- device stolen

Key recovery

Recovery procedure:

- 1 KRA retrieves the archived key from the CA database
- 2 KRA decrypts and delivers the private key to the user

Good practice:

- configure **Key Recovery Agent** on a secure, dedicated account
- export KRA certificate and private key to a secure location
 - e.g. offline storage
 - restore only when needed
- test the recovery process with a non-critical certificate

In the lab

You will:

- 1 Install and configure an **Enterprise Root CA** on a Windows Server 2025 domain member
- 2 Duplicate the built-in **Web Server** certificate template and configure it for your environment
- 3 Grant **Enroll** permission to the web server computer account on the template
- 4 Request and issue a certificate for IIS from the CA
- 5 Bind the certificate to the IIS website and verify HTTPS works without a browser warning



Bibliography

- [1] J. Krause, *Mastering windows server 2025 - fifth edition*. Packt Publishing, 2025.
- [2] "Active directory certificate services overview," 2024. <https://learn.microsoft.com/en-us/windows-server/identity/ad-cs/active-directory-certificate-services-overview> (accessed May 24, 2026).